

INCIDENT RESPONSE POLICY

Tumaini Capital Ltd | ISMS-POL-003 | ISO/IEC 27001:2022 — Annex A Controls 5.24–5.28 | Fictional case study

Document Title	Incident Response Policy	Document ID	ISMS-POL-003
Version	1.0	Status	<i>DRAFT — Pending Approval</i>
Author	Head of Risk & Compliance (ISMS Lead)	Date	June 2026
Approved By	ISMS Lead & CEO	Next Review	June 2027
Related Documents	ISMS-POL-001 (Information Security Policy), ISMS-POL-002 (Access Control Policy), ISMS-DOC-006 (Risk Assessment — R-007), DPA 2019 s.43		

1. PURPOSE

This policy establishes Tumaini Capital's requirements for managing information security incidents throughout their full lifecycle, from initial detection through containment, recovery, and post-incident review. It ensures that incidents are handled consistently, that the appropriate parties are notified within required timeframes, and that lessons learned are captured to prevent recurrence.

This policy is motivated by Tumaini Capital's experience of a 2025 CRM access incident that was not formally managed. That incident exposed customer telephone numbers and was resolved without a documented response process, root cause analysis, or corrective action. This policy ensures that any future incident is handled with the discipline the Data Protection Act, 2019 and ISO/IEC 27001:2022 require.

2. SCOPE

This policy applies to all information security events and incidents affecting Tumaini Capital's in-scope information systems, data, and physical assets, as defined in the ISMS Scope Statement (ISMS-DOC-001). It applies to all staff, contractors, and third-party suppliers who detect, respond to, or are involved in an information security incident.

3. DEFINITIONS

- Information security event: an identified occurrence suggesting a possible breach of information security policy or failure of controls, or a previously unknown situation that may be security-relevant. Not all events are incidents.
- Information security incident: a single or series of unwanted or unexpected information security events that have a significant probability of compromising business operations or information security.
- Personal data breach: a breach of security leading to the accidental or unlawful destruction, loss, alteration, unauthorized disclosure of, or access to, personal data.
- Near miss: a security event that did not result in actual harm but could have done so under different circumstances. Near misses shall be treated as incidents for reporting and review purposes.

4. INCIDENT SEVERITY CLASSIFICATION

All confirmed incidents shall be classified using the following scheme. Initial classification may be revised as investigation progresses.

Severity	Description	Example	Initial Response	ISMS Lead Notification
Critical	Widespread or catastrophic impact — mass data breach, ransomware, complete platform unavailability	Ransomware encrypting production AWS environment	Contain within 1 hour	Immediately (≤ 30 mins)
High	Significant confirmed impact — unauthorized access to systems, material data exposure, major system compromise	Former employee access to CRM post-exit	Contain within 4 hours	Within 2 hours
Medium	Moderate impact — suspected unauthorized access, minor data exposure, system degradation	Failed bulk data export attempt	Contain within 24 hours	Within 8 hours
Low	Minor impact — policy violation, lost device, failed phishing attempt with no compromise	Staff member clicking a phishing link (no credential entered)	Document within 5 days	Within 2 business days

5. ROLES AND RESPONSIBILITIES

5.1 Incident Manager

The ISMS Lead (Head of Risk & Compliance) serves as Incident Manager for all High and Critical incidents. For Medium and Low incidents, the Incident Manager role may be delegated to the Head of Engineering. The Incident Manager is responsible for: declaring an incident, coordinating the response, making escalation decisions, approving external communications, and ensuring the post-incident review is conducted.

5.2 Technical Responders

The Head of Engineering and the Engineering team are responsible for: technical containment and eradication actions, preserving system evidence, restoring affected systems and services, and providing technical briefings to the Incident Manager.

5.3 Communications Lead

The ISMS Lead is responsible for all external communications during an incident, including notifications to the ODPC, CBK, affected customers, and commercial partners. No external communications regarding an incident shall be made without the ISMS Lead's explicit approval.

5.4 All Staff

All staff are responsible for reporting suspected security events promptly through the reporting channel defined in Section 6.1. Staff shall not attempt to investigate or remediate a suspected incident independently.

6. INCIDENT RESPONSE LIFECYCLE

6.1 Detection and Reporting

Security events may be detected through automated monitoring (AWS CloudWatch alerts, CRM audit logs), staff observation, third-party notification, or external reports. Upon detecting a potential security event, staff shall:

- Report immediately to the ISMS Lead or designated incident reporting channel (a dedicated security reporting email address to be established as part of the ISMS implementation).

- Preserve any evidence available at the time (screenshots, log entries, device state). Do not delete, modify, or power off affected systems without instruction from the Incident Manager.
- Not discuss the incident externally or on personal social media.

The ISMS Lead shall acknowledge all reported events within two hours during business hours, and within four hours outside business hours.

6.2 Triage and Classification

Upon receiving a reported event, the Incident Manager shall assess the event and determine whether it constitutes an incident. If confirmed as an incident, the Incident Manager shall: assign a severity classification using the matrix in Section 4, open an incident record in the incident log, formally activate the response process, and notify the CEO for all High or Critical incidents.

6.3 Containment

Containment actions shall be taken immediately to limit the spread or impact of the incident. Containment shall not be delayed pending a full investigation. Typical containment actions may include:

- Disabling compromised user accounts or API credentials.
- Isolating affected systems from the network to prevent lateral movement.
- Blocking malicious IP addresses or disabling affected integrations (e.g. M-Pesa API).
- Applying emergency access control changes to the CRM or AWS environment.

All containment actions shall be logged with timestamps, the name of the person who performed them, and the system affected.

6.4 Eradication and Recovery

Following containment, the Engineering team shall identify and remove the root cause of the incident (eradication). Once eradication is confirmed, affected systems shall be restored from verified clean backups or rebuilt where necessary. Recovery shall be confirmed by the Head of Engineering before the incident is considered resolved. The Incident Manager shall document the date and time of recovery confirmation.

6.5 Post-Incident Review

A post-incident review shall be conducted for all High and Critical incidents within 14 days of incident closure, and for Medium incidents within 30 days. The review shall produce a written Post-Incident Report covering:

- Timeline of events: when the incident occurred, when it was detected, key response milestones.
- Root cause analysis: the technical and/or process failure that enabled the incident.
- Impact assessment: what data, systems, or people were affected.
- Response effectiveness: what worked well and what could be improved.
- Corrective actions: specific, assigned, and time-bound actions to prevent recurrence.

All corrective actions shall be tracked in the ISMS Corrective Action Register and followed up at the next management review.

7. ODPC NOTIFICATION REQUIREMENTS

Under Section 43 of the Data Protection Act, 2019, Tumaini Capital is required to notify the Office of the Data Protection Commissioner (ODPC) of a personal data breach without undue delay, and where feasible, within 72 hours of becoming aware of the breach.

The 72-hour clock starts when a member of Tumaini Capital's staff becomes aware that a personal data breach has likely occurred. The notification to the ODPC shall include:

- The nature of the personal data breach, including the categories and approximate number of data subjects concerned.
- The name and contact details of the Data Protection Officer or ISMS Lead.

- A description of the likely consequences of the breach.
- A description of the measures taken or proposed to address the breach, including measures to mitigate its possible adverse effects.

Where notification within 72 hours is not possible, Tumaini Capital shall notify the ODPC as soon as practicable and provide a reasoned justification for the delay. Where the breach is likely to result in a high risk to the rights of data subjects, affected individuals shall also be notified directly without undue delay.

The ISMS Lead is solely responsible for preparing and submitting ODPC notifications. No other person shall submit a notification without the ISMS Lead's explicit instruction.

8. EVIDENCE PRESERVATION

Preserving evidence is critical for regulatory compliance, potential legal proceedings, and root cause analysis. The following requirements apply to all High and Critical incidents:

- System logs, audit trails, and screenshots shall be preserved in their original form before any remediation action is taken.
- AWS CloudTrail logs, CRM audit logs, and authentication logs relevant to the incident shall be exported and secured in a dedicated incident evidence folder with access restricted to the Incident Manager.
- Physical evidence (e.g. a device suspected of compromise) shall not be powered off or modified without instruction from the Incident Manager or legal counsel.
- Evidence shall be retained for a minimum of five years or until any legal proceedings arising from the incident are concluded, whichever is longer.

9. TRAINING AND TESTING

All staff shall receive information security awareness training that includes instruction on how to identify and report security events. The ISMS Lead and Engineering team shall participate in a tabletop incident response exercise at least annually, simulating a realistic scenario relevant to Tumaini Capital's risk landscape. Exercise outcomes shall be documented and used to update this policy and the supporting incident response procedures.

10. REVIEW

This policy shall be reviewed annually, following any significant incident, and following any change to the applicable regulatory framework, including guidance issued by the ODPC.

Role	Name & Signature	Date
Head of Risk & Compliance / ISMS Lead (Author)		
Head of Engineering (Technical Owner)		
Chief Executive Officer (Approver)		